SLIIT

Discover Your Future

Pentesting IE3132

Kanishka Yapa

Lecture 4

Scanning the network

Understanding what you are doing.

- What is scanning?
- Types of scanning.
- What's the goal.
- What are the techniques used?
- What tools are used?



What is scanning?

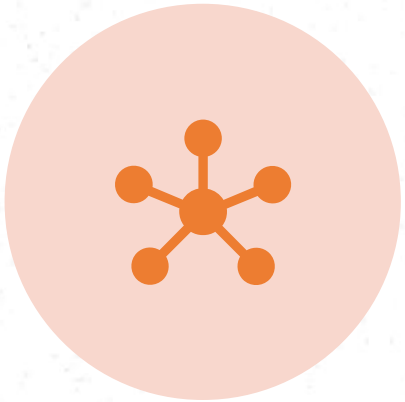
Looking for "Live" systems.

Identifying those systems.

Discovering what ports are open or closed.

Are those systems running any services?

Types of Scanning



NETWORK SCAN



PORT SCAN



VULNERABILITY SCAN

Network Scan



- Find all “Live” Hosts
- Possibly “see” OS’s
- Pick up IP address

Port Scan



192.168.56.100+HTTP

192.168.56.101:80

What is a port?

65,535 but focus on the first 1023

Which ports are responding?

Which services use these ports?

Vulnerability scan

- Identify possible threats to Apps/OS
- Identify possible vulnerabilities to Apps/OS
- Be proactive.



What's the Goal/Objective



What are the techniques used?



What tools are used?

- Command line- ping
- Nmap
- Solarwind-Network Topology Mapper
- Angry IP Scanner
- Nessus
- InSSIDer
- Many other…..

TCP Communication



Feature
Negotiate a connection
Delivery Acknowledgements
Retransmission/ Error Detection
In-order delivery
Congestion control
Bigger header/overhead (20 bytes)
Stream-oriented

UDP Communication

Feature
Connectionless based
Smaller packets(8 bytes)
Only one packet goes
Out of order delivery
No congestion control
Message oriented
Fast

Flags

SYN
Synchronization
Includes a sequence#

ACK
Acknowledgement

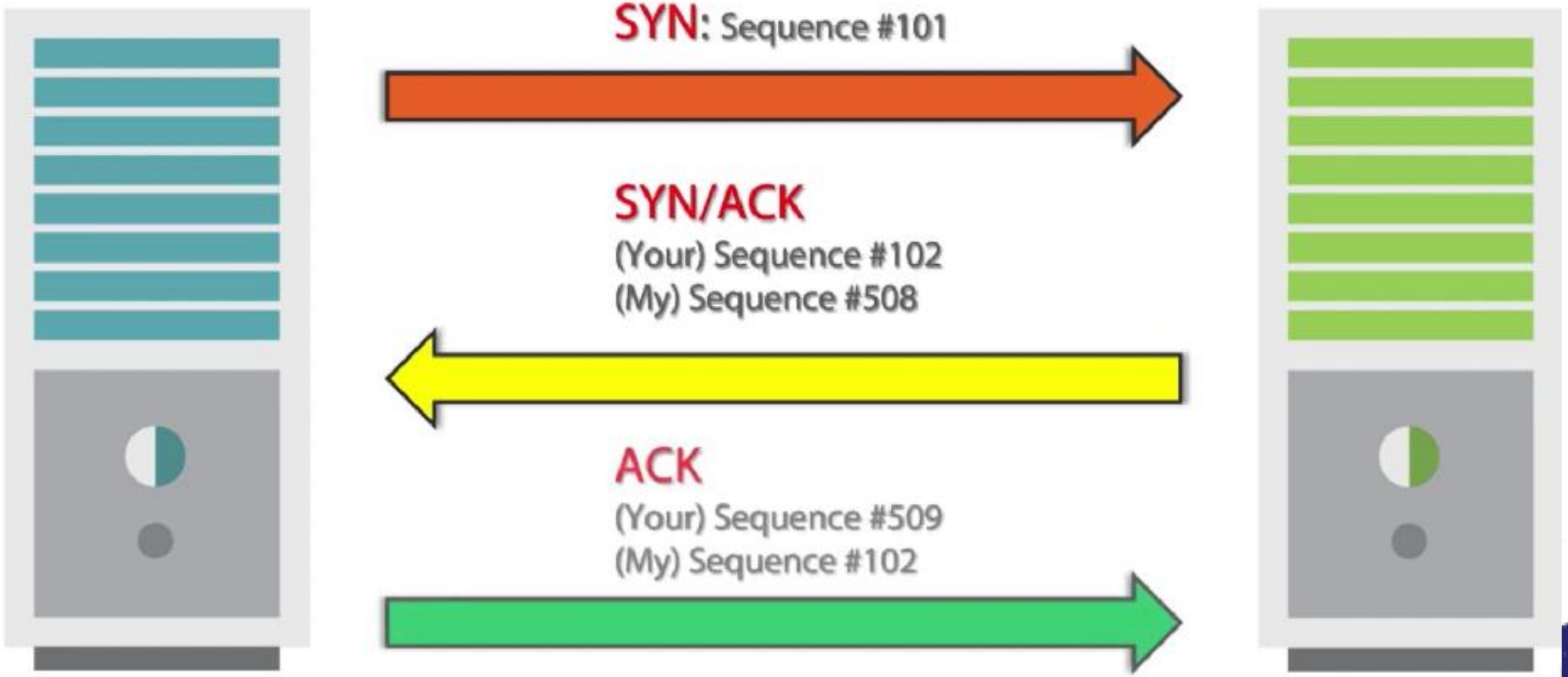
FIN
Finish

PSH
Push

URG
Urgent

RST
Reset

3-way Handshake




FIN:
I wanna stop now…
ACK/FIN
OK…Tell App to Stop
App Stopped….I'm done

Demo



3-way handshake on Wireshark

Is it Alive!



- ICMP sweep- Angry IP scanner / ping
- Port scan

Network Scanning - NMAP



- BEFORE WE GET STARTED

1) DO NOT ATTEMPT TO SCAN ANY NETWORK OR MACHINE WITHOUT WRITTEN PERMISSION FROM AN AUTHORISED PERSON!

2) SCANNING SOME SYSTEMS (ESPECIALLY IN AN AGGRESSIVE MODE) MAY LEAD TO THE SYSTEMS CRASHING (SCADA IS A TYPICAL CASE)

Cheat Sheet

https://www.stationx.net/nmap-cheat-sheet/

Nmap ("Network Mapper")



- Nmap ("Network Mapper") is a free and open source tool for network discovery and security auditing.
- It can be used by network administrators to do :
- network inventory,
- managing service upgrade schedules, and monitoring host or service uptime.

Nmap ("Network Mapper")

Nmap can determine:

- what hosts are available on the network,
- what services (application name and version) those hosts are offering,
- what operating systems (and OS versions) they are running,
- what type of packet filters/firewalls are in use

Nmap ("Network Mapper")

In addition to the classic command-line Nmap executable, the Nmap suite includes:

- an advanced GUI and results viewer (Zenmap),
- a flexible data transfer, redirection, and debugging tool (Ncat),
- a utility for comparing scan results (Ndiff), and
- a packet generation and response analysis tool (Nping).
- Nmap runs on all major computer operating systems, and official binary packages are available for Linux, Windows, and Mac OS X.

NMAP – the Pentester TOOL



- The TOOL for network pen tests - does discovery and even checks for susceptibility to some exploits
- It is a tool that can be extended - you can write scripts (quite a number available already) to do something that you find useful - need to know the scripting language to do so –
- The tool can be as blunt and refined as you want it
- Pentest goal - discover information without being detected - avoiding defences whenever possible
- A standard scan is quite “loud” - lots of requests sent to systematically probe default ports, services and OS specific responses
- Most systems that have decent firewall and a cautious security policy will ignore a PING scan

nmap scanme.nmap.org/



- ……we set up this machine to help folks learn about Nmap and also to test and
- make sure that their nmap installation (or Internet connection) is working properly.
- You are authorized to scan this website with nmap or other port scanners.
- Try not to hammer on the server too hard. A few scans in a day is fine, but don't scan 100 times a day or use this site to test your ssh brute-force password cracking tool.

https://www.nirsoft.net/countryip/

You can use this website to find any country IP address range

NMAP Scan Options

- Standard Single Target Scan
  - nmap <target>
  - nmap 192.168.0.110
- Multiple Target Scanmmap <targetA targetB targetC …>
  - nmap 192.168.0.110 192.168.0.111
- Or one can specify a range
  - nmap 192.168.0.100-120
- What if I want to specify a subnet?
  - nmap <subnet/CIDR>
  - nmap 192.168.0.0/24

Scan Techniques

Switch	Example	Description
-sS	nmap 192.168.1.1 -sS	TCP SYN port scan (Default)
-sT	nmap 192.168.1.1 -sT	TCP connect port scan (Default without root privilege)
-sU	nmap 192.168.1.1 -sU	UDP port scan
-sA	nmap 192.168.1.1 -sA	TCP ACK port scan
-sW	nmap 192.168.1.1 -sW	TCP Window port scan
-sM	nmap 192.168.1.1 -sM	TCP Maimon port scan

https://www.stationx.net/nmap-cheat-sheet/

NMAP Scan Options

- What if we want more than just a basic scan?
- To get a better picture of the target you can use the **-A** option which will attempt to perform a **detailed & aggressive scan** of the target/s.
  - nmap -v -A 192.168.0.110

- Sometimes, your target is configured to **block** all attempts to "**ping it**".
  - Use the **-Pn** option to run the scan.
    - **nmap -v -Pn -sU -sS 192.168.57.xx**
  - Assumes that the target is online and allows the scan to continue when the target is protected by a firewall.
  - Saves time - skips the discovery check

NMAP Scan Options

- Sometimes we need to exclude specific systems that may be running

business critical processes

- Use --exclude
- nmap 192.168.0.0/24 --exclude 192.168.0.200
- Nmap can use input files to run scans - just compile the list in a text file and use it as input (-iL switch)

NMAP - Controlling the Probes Timing & Scanning Larger Networks



- Timing Options
- A total of six options available
- Default timing uses median value
- Timing can be specified by -T[X] option
- nmap -T5 192.168.0.110
- T5 is the fastest and most aggressive option - default is T3
- Firewalls and IDSes are almost certain to detect the default scan - need
to slow down
- Try -T1 if you have the time (-T0 if you really, really have lots of time)

NMAP - Controlling the Probes Timin
Scanning Larger Networks

- Divide and Conquer
- Option 1 - divide into groups
- Use --min-hostgroup
- specifies the minimum number of targets to be scanned in parallel
- nmap --min-hostgroup 30 192.168.0.0/24
- Option 2 - use multiple machines to run the scans

NMAP Scan Options

What if we need to check only specific ports?

- Use the -p option; For example, for a standard HTTP check
- nmap 192.168.0.110 -p 80
- Multiple ports can be specified by separate commas
- nmap 192.168.0.110 -p 80,20
- To scan all ports, specify the range
- nmap 192.168.0.110 -p1-65535

NMAP Scan Options

- OS and Service Detection - Critical for exploit selection
- OS detection - relies on the responses from the target - provides a well-educated guess
- Older OS versions are typically better recognised
- nmap -O 192.168.0.110
- What if NMAP does not recognise the OS?
- You can force it to guess – do not expect accurate results
- nmap -O -osscan-guess 192.168.57.110
- The version of the service running can on the open port be obtained via the -sV option
- nmap -sV 192.168.0.110

NMAP Scan Options

- -sF FIN scan - similar to the NULL scan; the FIN flag is set
- -sX Christmas scan - URG, FIN and PSH flags are set
- --scanflags <flags> - allows users to craft flag activation
- nmap 192.168.57.100 --scanflags PSHURGSYN
- It will activate the PSH, URG, and SYN TCP header flags
- -F - runs a fast scan of the target - only 100 ports checked instead of 1000
- nmap -F 192.68.57.110
- --packet-trace - shows summary of the traffic sent/ received
- nmap --packet-trace 192.168.0.110
- --top-ports =10 - TCP connect scan for the top ten TCP ports
- -A - OS version detection
- -O - OS fingerprinting

NMAP Scan Options

- -A: Enable OS detection, version detection, script scanning, and traceroute
- -v: Increase verbosity level (use -vv or more for greater effect)
- -p <port ranges>: Only scan specified ports
- --reason: Display the reason a port is in a particular state
- --open: Only show open (or possibly open) ports
- -sV: Probe open ports to determine service/version info

NMAP Scan Options



- -sU: UDP Scan
- -sn: Ping Scan - disable port scan
- -oN/-oX/-oS/-oG <file>: Output scan in normal, XML, s|<rIpt kIddi3, and Grepable

format, respectively, to the given filename.

- nmap -vv -p 22 -oG - 192.168.57.0-255 > /home/scanOutput1.txt
- -iL <inputfilename>: Input from list of hosts/networks

NMAP Scan Options



- nmap -p 1-65535 192.168.56.100
- -PR (ARP ping scan - can speed up the processing on a local network)
- -n (disable reverse DNS - can save a lot of time)
- --traceroute (runs trace route)
- -sS TCP SYN scan - default option checks 1000 common TCP ports (Stealth/SYN Scanning)
- -sN TCP NULL scan - aim is to get a reply from the firewalls protecting the target; none of the flags are set in the packets sent - some firewalls provide a response, some do not

Combining nmap and external script to enhance the scanning



- https://nmap.org/nsedoc/scripts/firewall-bypass.html

MASSCAN: Mass IP port scanner

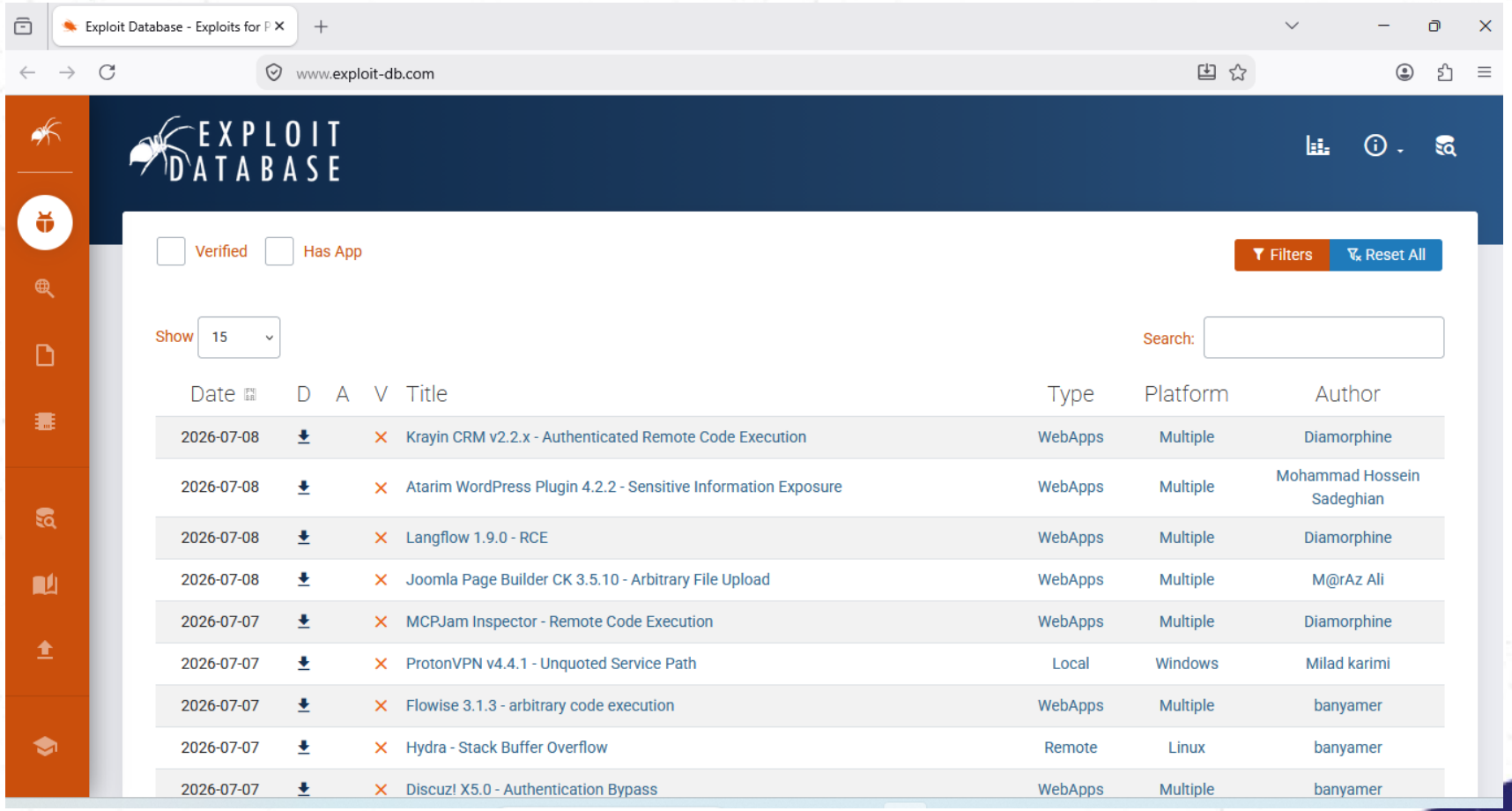


- https://github.com/robertdavidgraham/masscan

This is an Internet-scale port scanner. It can scan the entire Internet in under 5 minutes, transmitting 10 million packets per second, from a single machine.

- sudo masscan -p22 192.168.57.0/24
- How to scan the entire Internet
- masscan 0.0.0.0/0 -p0-65535
- Banner checking
- masscan 10.0.0.0/8 -p80 --banners --source-ip 192.168.57.143

https://www.exploit-db.com/ is a one of the useful resources to find existing vulnerabilities



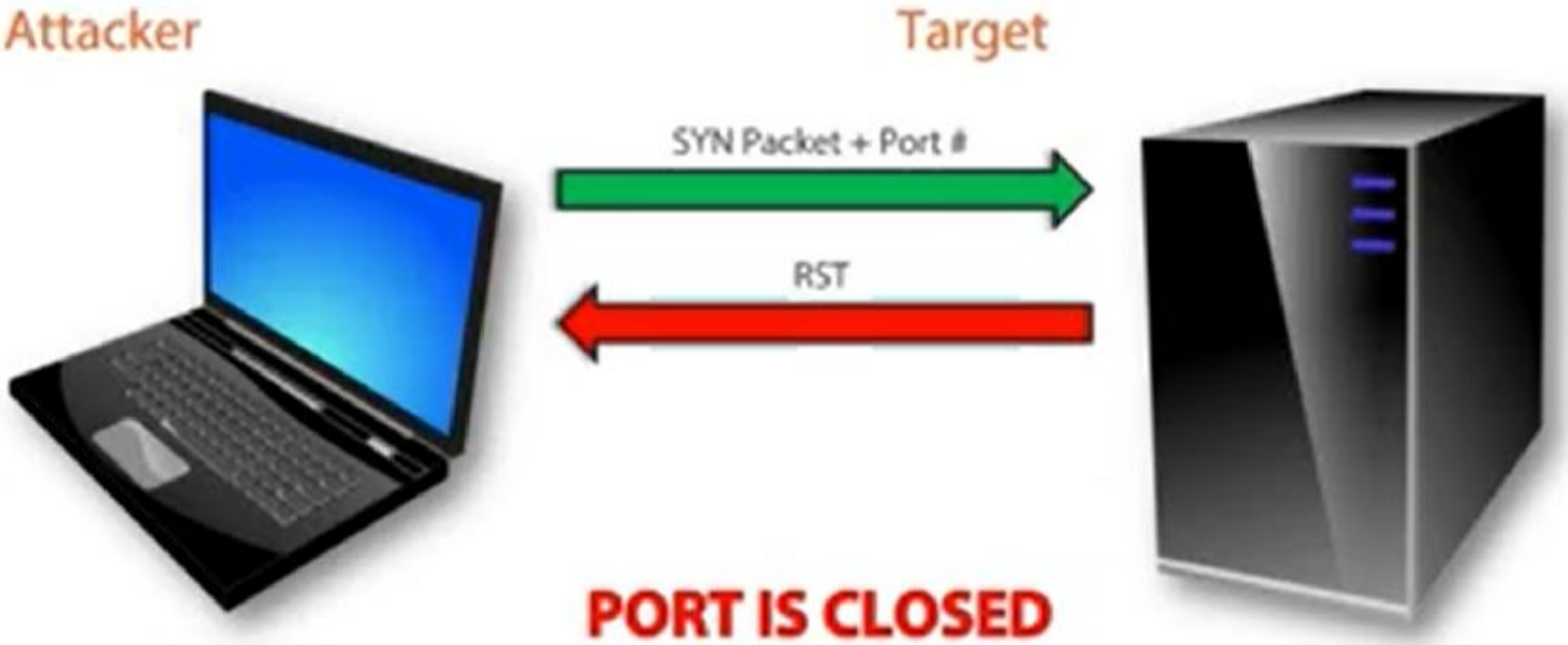
Types of scans

- Full scans
- Half-open scans
- Xmas tree scans
- FIN scans
- NULL scans
- UDP scans
- Countermeasures

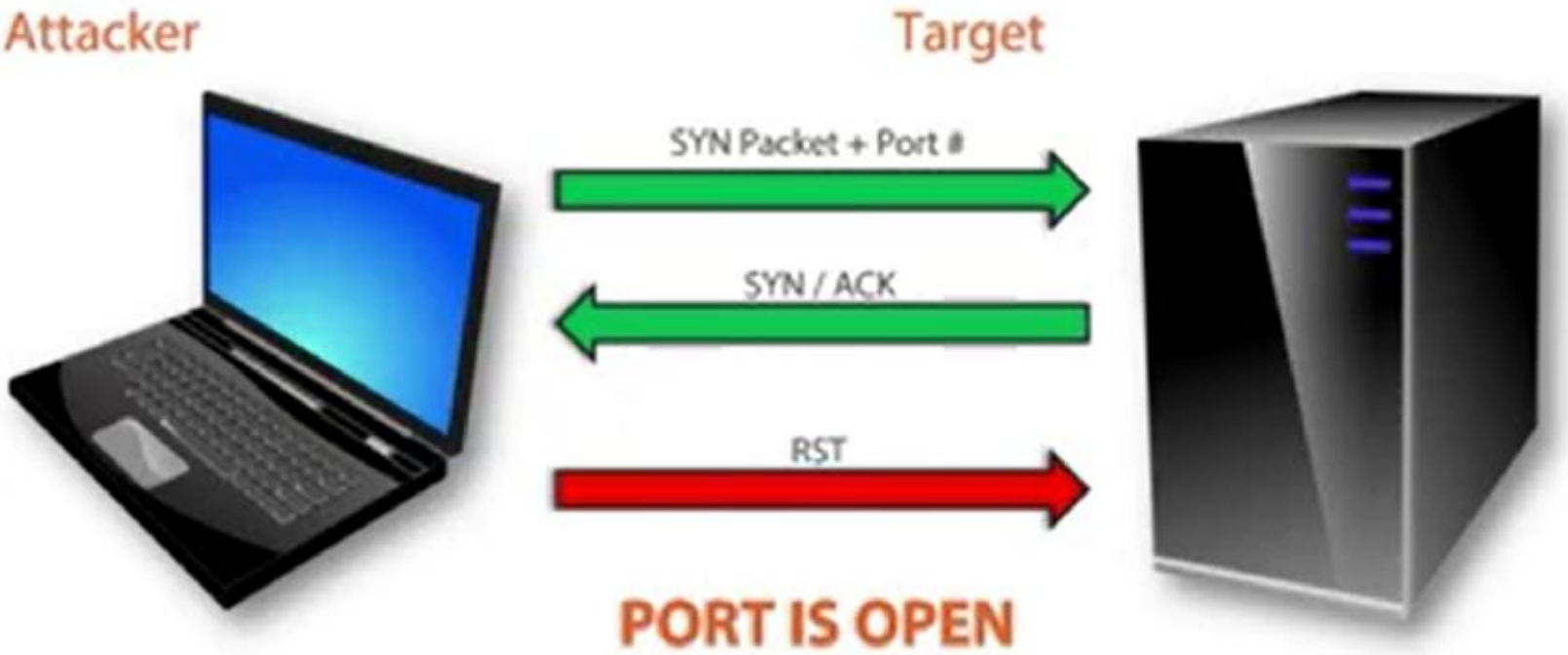
Full scan



Full scan



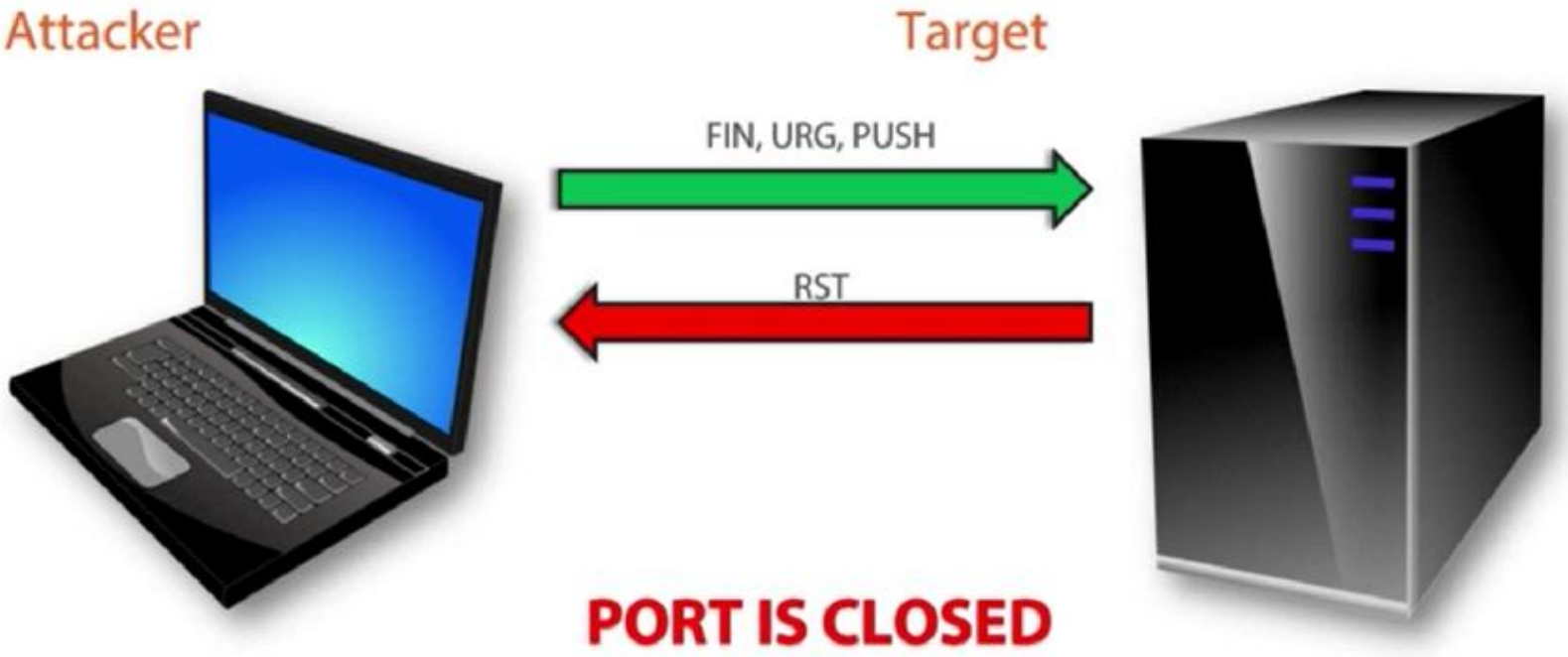
Half open scan- stealth scan



Xmas tree scan



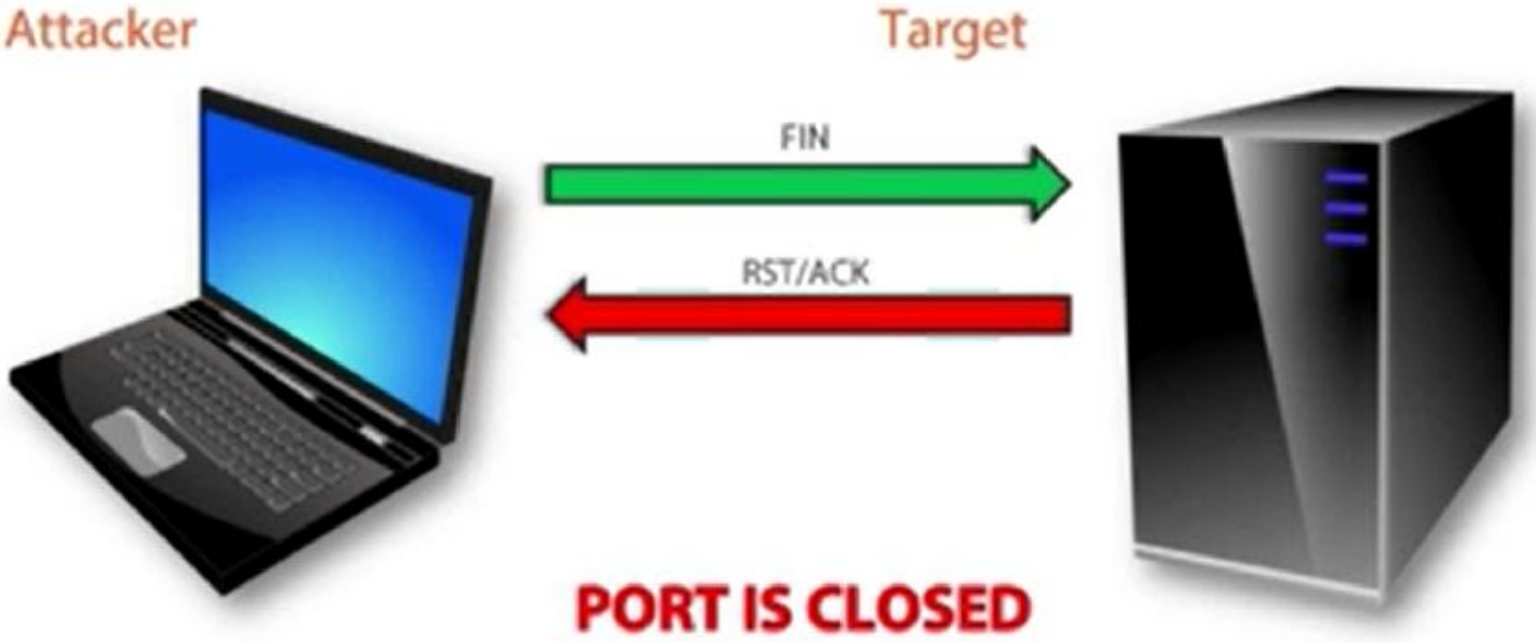
Xmas tree scan



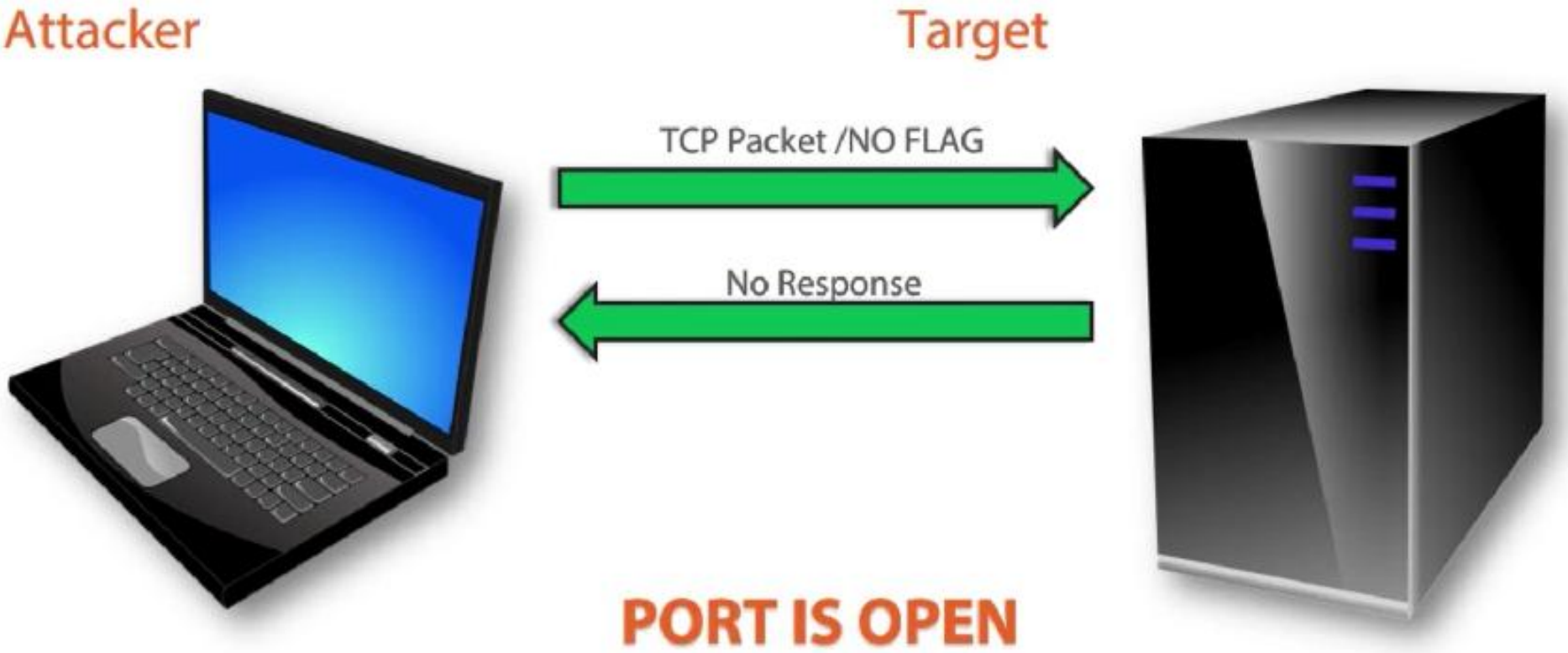
FIN Scan



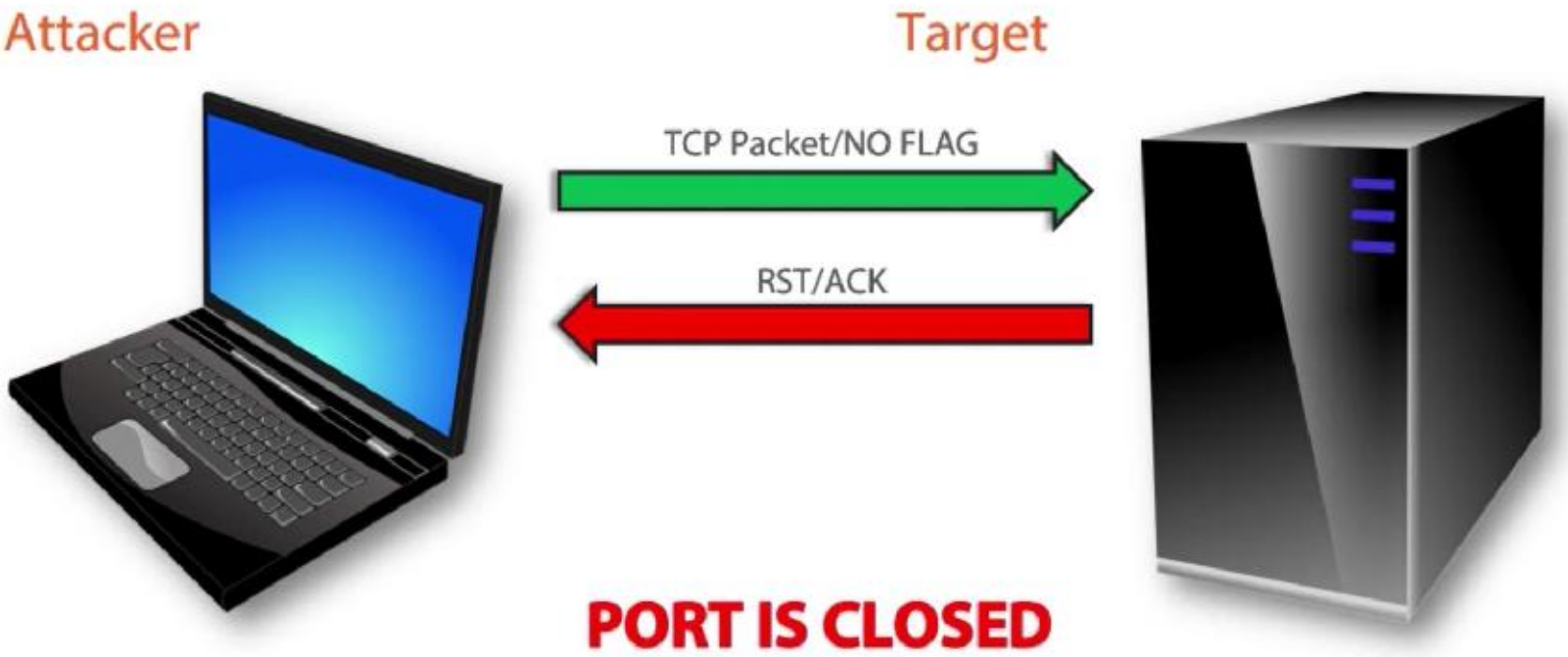
FIN Scan



Null Scan



Null Scan



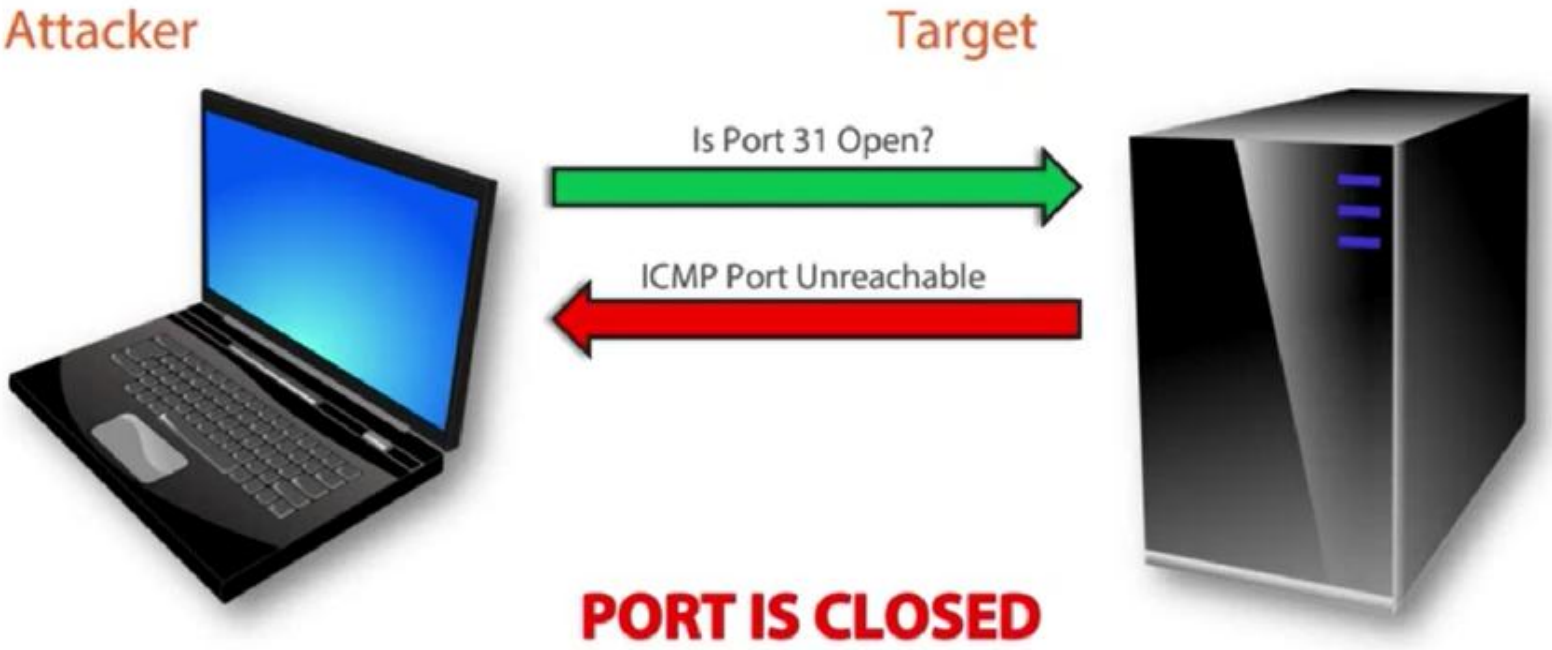
UDP Scan

- No 3-way handshake
- Advantages
- Harder to monitor
- No TCP overhead/ # Frames can be larger
- Very effective against Windows targets
- Disadvantages
- Port data only

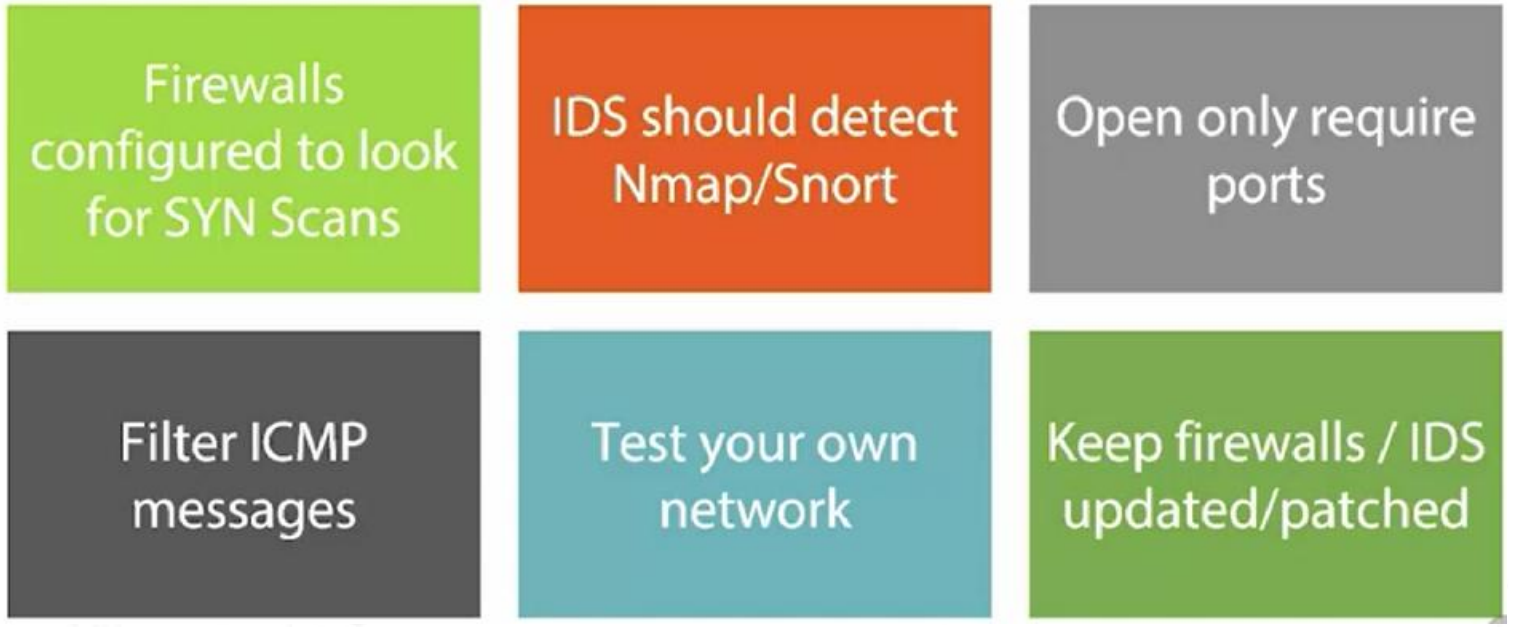
UDP Scan



UDP Scan


Attacker
Target
Is Port 31 Open?
ICMP Port Unreachable
PORT IS CLOSED

Countermeasures



Banner Grabbing & OS Fingerprinting

- OS Fingerprinting attempts to determine the host via packets

Two types

Active Fingerprinting

- Uses specially crafted packets
- Reponses are compared to a database of known responses
- Extremely high chance of detection

Passive Fingerprinting

- Sniffs network traffic
- Responses are analyzed to discover any details that could ID the system
- Chances of detection are extremely low

Countermeasures



- Misdirection / fake banners
- IIS lockdown tool
- ServerMask
- Turn off unused services
- Change the ServerSignature (httpd.conf)
- Speaking of httpd.conf: mod_headers



Any Questions?